

Consegna Settimana 3 / Lezione 5 - Progetto

Relazione

Obiettivo:

Sulla base di quanto visto, creare una regola firewall che blocchi l'accesso alla DVWA (su metasploitable) dalla macchina Kali Linux.

Svolgimento:

Per fare quanto richiesto dobbiamo innanzitutto andare su VirtualBox e configurare le reti delle macchine virtuali di Kali, Metasploitable e di PfSense.

Kali e Metasploitable vanno messe su Rete Interna, ma con nomi diversi. Nel nostro caso la rete di Kali sarà *kalinet* e di Metasploitable sarà *metanet*.

A questo punto dobbiamo configurare PfSense, la prima rete sarà quella preimpostata collegata a internet, mentre le altre due reti che attiveremo saranno reti interne collegate rispettivamente a kalinet e metanet.

Aperto PfSense dobbiamo ora configurare le reti collegate, associando degli indirizzi ip.

La prima rete sarà quella di PfSense che configureremo in automatico con DHCP.

A kalinet assoceremo: 192.168.10.1/24

A metanet assoceremo: 192.168.50.1/24

Il risultato finale della configurazione apparirà così:

```
You can now access the webConfigurator by opening the following URL in your web browser:
      http://192.168.50.1/

Press <ENTER> to continue.
VirtualBox Virtual Machine - Netgate Device ID: e542913a28f6b24e0281

*** Welcome to pfSense 2.7.2-RELEASE (amd64) on pfSense ***

WAN (wan)      -> vtnet0      -> v4/DHCP4: 10.0.2.15/24
                                   v6: fd17:625c:f037:2:a00:27ff:fe12:de2e/64
LAN (lan)      -> vtnet1      -> v4: 192.168.10.1/24
OPT1 (opt1)    -> em0        -> v4: 192.168.50.1/24

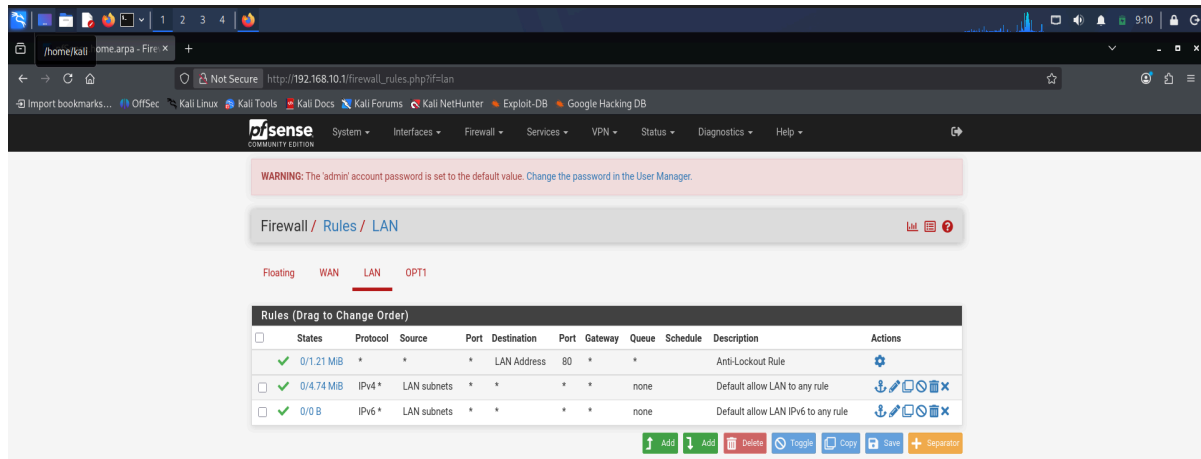
0) Logout (SSH only)          9) pfTop
1) Assign Interfaces          10) Filter Logs
2) Set interface(s) IP address 11) Restart webConfigurator
3) Reset webConfigurator password 12) PHP shell + pfSense tools
4) Reset to factory defaults  13) Update from console
5) Reboot system              14) Enable Secure Shell (sshd)
6) Halt system                 15) Restore recent configuration
7) Ping host                   16) Restart PHP-FPM
8) Shell

Enter an option: █
```

Adesso possiamo aprire il pannello di PfSense dal browser di Kali.

Andiamo su “Firewall” e poi “Rules” per creare le regole del nostro firewall e poi clicchiamo sulla rete “LAN”.

Ritrovandoci in questa schermata.

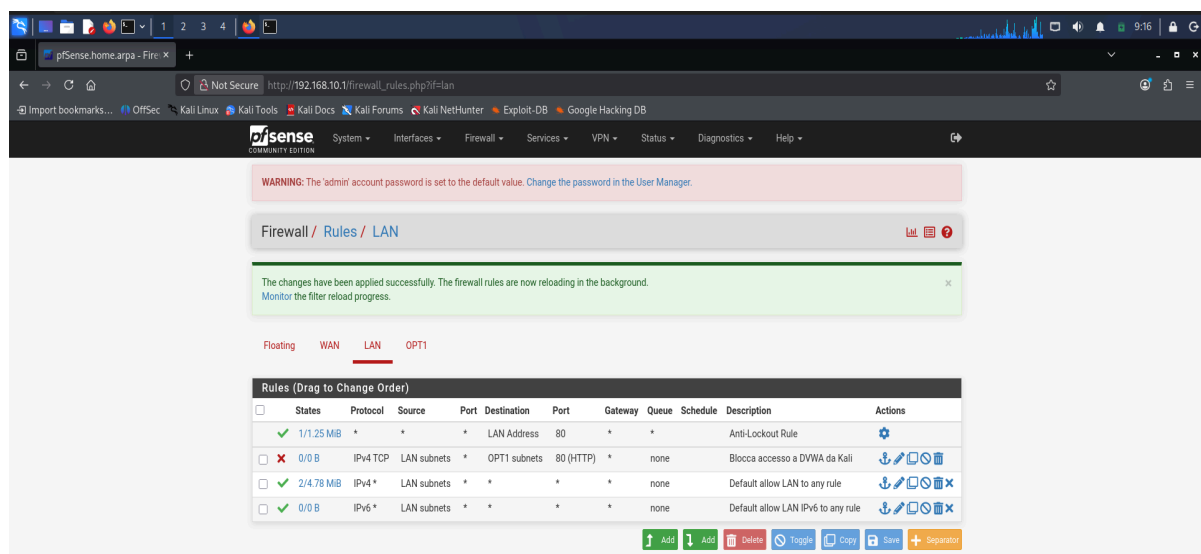


Da qui possiamo aggiungere la nostra regola cliccando sul pulsante “Add” con la freccia in alto, in modo da darle una priorità superiore.

L'azione che vogliamo fare è un blocco sull'interfaccia LAN, vogliamo bloccare il protocollo TCP, la porta di destinazione sarà la porta 80 del HTTP.

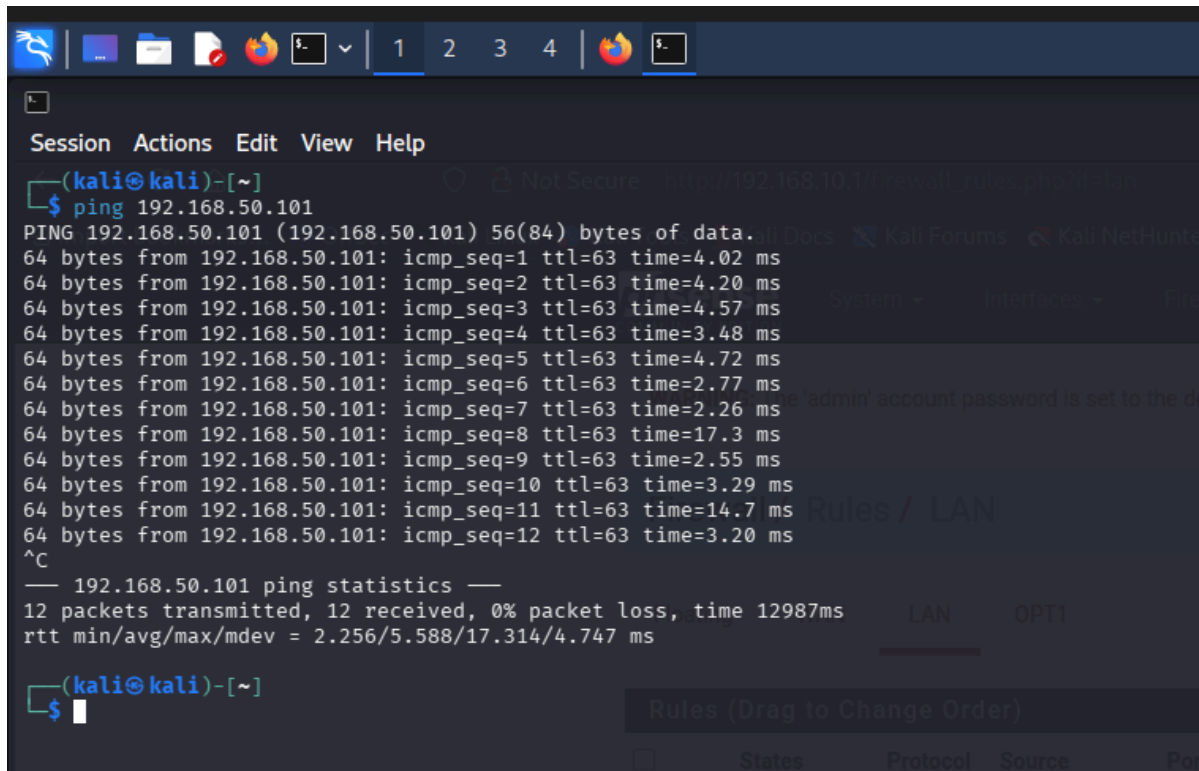
Come origine del blocco possiamo impostare l'ip specifico della kali o l'intera sottorete e la stessa cosa vale con la destinazione del blocco, infatti possiamo inserire sia l'ip specifico della metasploitable che l'intera sottorete. Nel caso specifico di questo esercizio, per comodità, ho messo le due sottoreti.

Una volta salvati i settaggi, la regola apparirà così a schermo:



A questo punto abbiamo fatto quanto richiede l'esercizio e possiamo controllare il risultato.

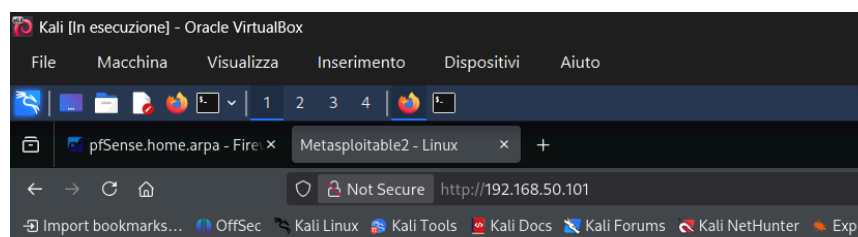
Prima di creare la nostra regola sul firewall infatti era possibile sia mandare un ping dalla kali verso la metasploitable



```
(kali㉿kali)-[~]
$ ping 192.168.50.101
PING 192.168.50.101 (192.168.50.101) 56(84) bytes of data:
64 bytes from 192.168.50.101: icmp_seq=1 ttl=63 time=4.02 ms
64 bytes from 192.168.50.101: icmp_seq=2 ttl=63 time=4.20 ms
64 bytes from 192.168.50.101: icmp_seq=3 ttl=63 time=4.57 ms
64 bytes from 192.168.50.101: icmp_seq=4 ttl=63 time=3.48 ms
64 bytes from 192.168.50.101: icmp_seq=5 ttl=63 time=4.72 ms
64 bytes from 192.168.50.101: icmp_seq=6 ttl=63 time=2.77 ms
64 bytes from 192.168.50.101: icmp_seq=7 ttl=63 time=2.26 ms
64 bytes from 192.168.50.101: icmp_seq=8 ttl=63 time=17.3 ms
64 bytes from 192.168.50.101: icmp_seq=9 ttl=63 time=2.55 ms
64 bytes from 192.168.50.101: icmp_seq=10 ttl=63 time=3.29 ms
64 bytes from 192.168.50.101: icmp_seq=11 ttl=63 time=14.7 ms
64 bytes from 192.168.50.101: icmp_seq=12 ttl=63 time=3.20 ms
^C
— 192.168.50.101 ping statistics —
12 packets transmitted, 12 received, 0% packet loss, time 12987ms
rtt min/avg/max/mdev = 2.256/5.588/17.314/4.747 ms

(kali㉿kali)-[~]
$
```

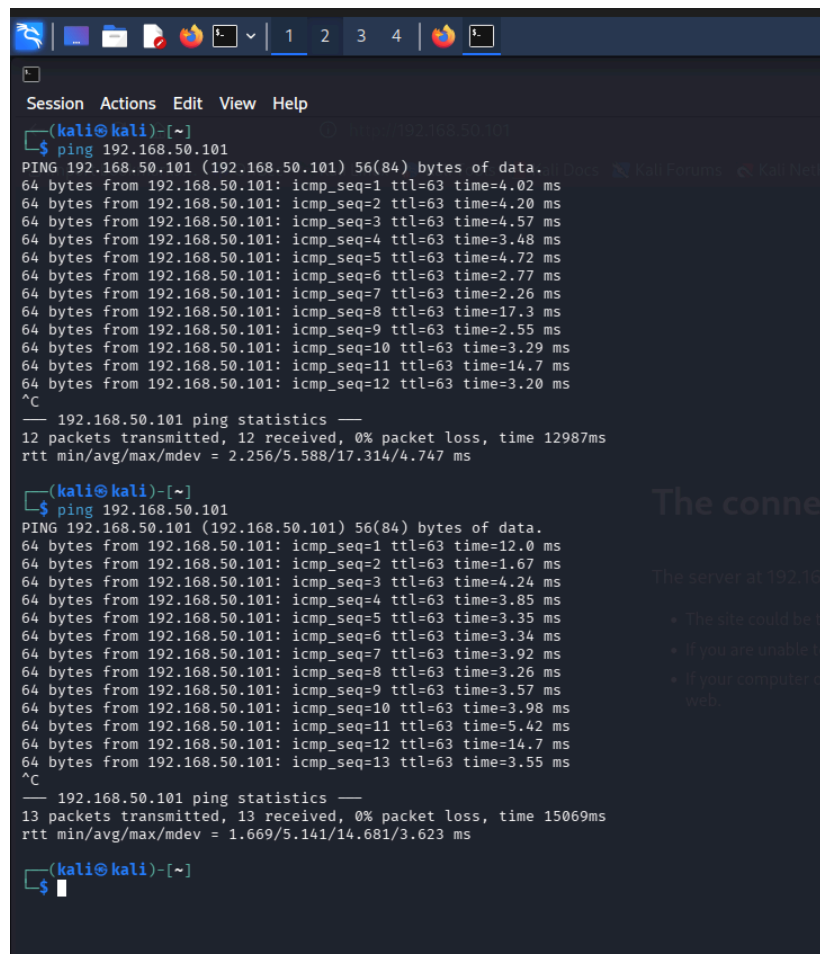
sia poter accedere dal browser della kali alla pagina servita della Metasploitable



Warning: Never expose this VM to an untrusted network!
Contact: msfdev[at]metasploit.com
Login with msfadmin/msfadmin to get started

- [TWiki](#)
- [phpMyAdmin](#)
- [Mutillidae](#)
- [DVWA](#)
- [WebDAV](#)

Dopo aver attivato il blocco nel firewall rimane possibile mandare un ping dalla kali alla metasploitable



```
(kali@kali)-[~]
$ ping 192.168.50.101
PING 192.168.50.101 (192.168.50.101) 56(84) bytes of data:
64 bytes from 192.168.50.101: icmp_seq=1 ttl=63 time=4.02 ms
64 bytes from 192.168.50.101: icmp_seq=2 ttl=63 time=4.20 ms
64 bytes from 192.168.50.101: icmp_seq=3 ttl=63 time=4.57 ms
64 bytes from 192.168.50.101: icmp_seq=4 ttl=63 time=3.48 ms
64 bytes from 192.168.50.101: icmp_seq=5 ttl=63 time=4.72 ms
64 bytes from 192.168.50.101: icmp_seq=6 ttl=63 time=2.77 ms
64 bytes from 192.168.50.101: icmp_seq=7 ttl=63 time=2.26 ms
64 bytes from 192.168.50.101: icmp_seq=8 ttl=63 time=17.3 ms
64 bytes from 192.168.50.101: icmp_seq=9 ttl=63 time=2.55 ms
64 bytes from 192.168.50.101: icmp_seq=10 ttl=63 time=3.29 ms
64 bytes from 192.168.50.101: icmp_seq=11 ttl=63 time=14.7 ms
64 bytes from 192.168.50.101: icmp_seq=12 ttl=63 time=3.20 ms
^C
--- 192.168.50.101 ping statistics ---
12 packets transmitted, 12 received, 0% packet loss, time 12987ms
rtt min/avg/max/mdev = 2.256/5.588/17.314/4.747 ms

(kali@kali)-[~]
$ ping 192.168.50.101
PING 192.168.50.101 (192.168.50.101) 56(84) bytes of data:
64 bytes from 192.168.50.101: icmp_seq=1 ttl=63 time=12.0 ms
64 bytes from 192.168.50.101: icmp_seq=2 ttl=63 time=1.67 ms
64 bytes from 192.168.50.101: icmp_seq=3 ttl=63 time=4.24 ms
64 bytes from 192.168.50.101: icmp_seq=4 ttl=63 time=3.85 ms
64 bytes from 192.168.50.101: icmp_seq=5 ttl=63 time=3.35 ms
64 bytes from 192.168.50.101: icmp_seq=6 ttl=63 time=3.34 ms
64 bytes from 192.168.50.101: icmp_seq=7 ttl=63 time=3.92 ms
64 bytes from 192.168.50.101: icmp_seq=8 ttl=63 time=3.26 ms
64 bytes from 192.168.50.101: icmp_seq=9 ttl=63 time=3.57 ms
64 bytes from 192.168.50.101: icmp_seq=10 ttl=63 time=3.98 ms
64 bytes from 192.168.50.101: icmp_seq=11 ttl=63 time=5.42 ms
64 bytes from 192.168.50.101: icmp_seq=12 ttl=63 time=14.7 ms
64 bytes from 192.168.50.101: icmp_seq=13 ttl=63 time=3.55 ms
^C
--- 192.168.50.101 ping statistics ---
13 packets transmitted, 13 received, 0% packet loss, time 15069ms
rtt min/avg/max/mdev = 1.669/5.141/14.681/3.623 ms

(kali@kali)-[~]
$
```

ma se proviamo ad accedere dal browser della kali alla pagina servita della Metasploitable veniamo bloccati dal firewall, come richiesto. Lo possiamo vedere proprio dal fatto che la pagina non viene caricata dal browser.

